SecureWealth Twin — Supporting Document

Punjab & Sind Bank Hackathon Series 2026 · Team **[TEAM NAME]** — Swayam, Mahak, Archit, Ayush, Vishwas, Aayat

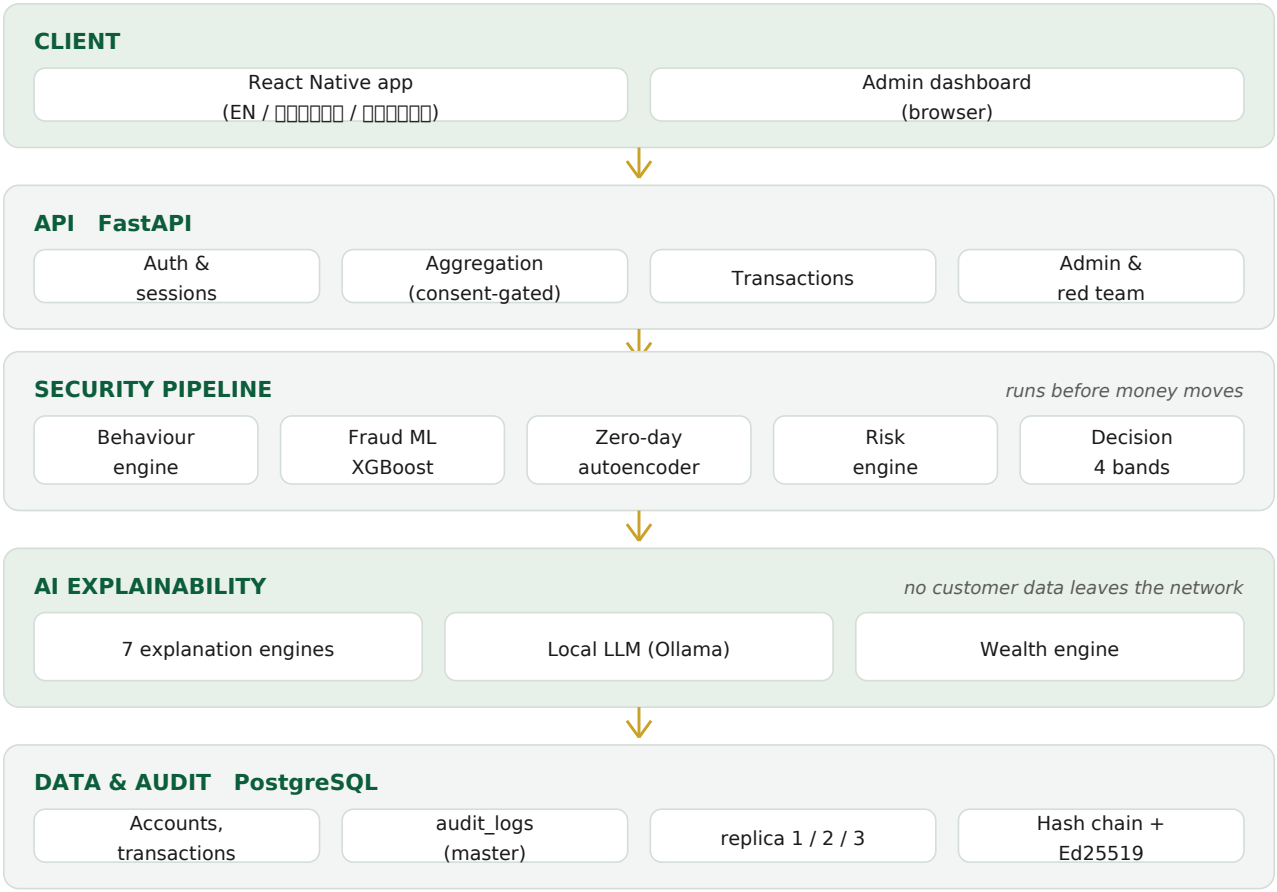
SecureWealth Twin is a retail banking application in which wealth management and fraud defence share a single decision path. Every investment is judged by the same pipeline that produces the customer's financial advice, and both the advice and the security verdict are explained back to the customer in plain language, in English, Hindi or Punjabi. The application only ever moves money into mutual funds and deposits.

> **The idea in one sentence.** Advice a customer can trust because the engine is willing to recommend nothing, and security they can understand because every decision explains itself — with the reasoning recorded in an audit trail that survives an attack from inside the bank.

1. Top features

Feature	What it does	Why it matters
Advice that can decline	When investable surplus is at or near zero, the engine suppresses all product recommendations and tells the customer to address expenses first.	A wealth engine that cannot say no is a sales funnel. This is the clearest separation between advice and distribution.
Per-customer fraud thresholds	There is no fixed rupee limit. Every threshold derives from that customer's own 90-day history, so ₹95,000 is challenged for one customer while ₹90,000 passes for another.	Fixed limits punish high-value customers and let low-value fraud through. Behaviour is the correct baseline.
Insider-resistant audit	Hash chain, Ed25519 signature per record, four copies. Conflicts resolve by signature authority, not majority vote, so a single genuine copy defeats three forged ones.	The realistic threat to an audit trail is a privileged insider, not disk failure. Majority voting loses to that attacker.
Zero-day novelty detection	A PyTorch autoencoder trained only on legitimate behaviour scores reconstruction error against p95/p99 thresholds.	Rules only catch what someone anticipated. This flags patterns nobody wrote a rule for — and when unsure, it challenges rather than allows.
Explanations in three languages	Seven explainability engines turn engine output into plain language via a locally hosted LLM, with deterministic templates as fallback.	A decision a customer cannot understand cannot be contested. Local hosting keeps financial data inside the bank.
“I didn't start this”	One tap on a held investment stops the money and files a report.	Turns the customer into a detection channel at the exact moment they have the most context.

2. High-level architecture



Requests flow downward. The security pipeline sits between the API and the data layer, so **no investment reaches the database without a decision** — fraud is judged before money moves rather than reconciled afterwards. The explainability layer reads the decision that was already made; it never influences it, which keeps the language model out of the security-critical path.

3. Other features

Area	Capability
Onboarding	Self-registration issuing a SecureWealth ID; phone numbers are never accepted as a login identifier.
Consent	Account-aggregation APIs refuse to answer without explicit consent and return 403; consent is revocable from the profile screen.
Step-up verification	MPIN, security question, OTP and biometric, with a compensation rule that preserves the assurance level when a customer switches method mid-challenge.
Customer security history	“My Security Activity” shows the customer every check that ran on their account, sourced from the audit chain.
Phishing protection	Manual message check and bulk inbox scan, with a threat-detail explanation of why a message was scored as it was.
Wealth intelligence	Net worth, cash flow, deposits, loans, financial-health grade across four dimensions, and prioritised recommendations restricted to mutual funds and deposits.
Admin console	Overview metrics, filterable audit search, investment reconciliation, live chain-integrity seal and a red-team console running ten real attack scenarios.

Area	Capability
Accessibility & i18n	Full EN/HI/PA coverage verified by an automated key-parity check; every icon-only control carries an accessibility label.

4. Security aspects

4.1 Authentication and access control

Control	Implementation
Credential storage	MPINs are hashed with bcrypt. They are never stored, logged or returned in clear text.
Login identifier	Only the issued SecureWealth ID is accepted. A leaked phone number is not a route in — verified by an automated test that asserts a 401.
Sessions	Token-based, stateless, carried per request; no server-side session store to hijack.
Device binding	Every device is registered and carries a trust state that feeds 25% of the risk score.
Administrative access	Separate admin key on all admin endpoints; wrong or missing keys return 401, covered by tests.
Step-up	Required before money moves for anything anomalous; a wrong answer is rejected without revealing which factor failed.

4.2 Data protection

Customer data is held in managed PostgreSQL with encryption at rest, and all transport is over TLS. The most consequential decision is architectural rather than cryptographic: **the language model runs locally**. Explanations are generated on the bank's own infrastructure, so customer balances, transactions and risk verdicts are never transmitted to a third-party AI provider. Consent gating means aggregation data is not even assembled until the customer has agreed to it.

4.3 Fraud detection

Detection is in-line and pre-transaction. The risk score is a weighted composition, and the weights are asserted to sum to 1.0 at import — the application refuses to start otherwise.

Input	Weight	Source	Band	Score	Outcome
AI fraud probability	0.35	XGBoost, 22 features	ALLOW	0–30	No friction
Behavioural signals	0.25	8 rules with published thresholds	WARN	31–55	Advisory shown
Device trust	0.25	Status penalty × confidence	CHALLENGE	56–79	Step-up required
Environmental	0.15	IP region, login gap, network	BLOCK	80–100	Stopped and reported

Behavioural rules include amount spikes against the customer's own z-score and median, velocity bursts of three or more transactions in five minutes, OTP entry under 2.5 seconds (bot or coercion) or beyond 60 seconds (relay), night-hours activity, unseen funds, and round-number frequency as a mule indicator. Thresholds are referenced to RBI 2025-26/219, NIST SP 800-63B and FATF Recommendation 16, and all of them live in a single rules registry so no threshold is hardcoded elsewhere.

4.4 Audit integrity

Every decision — including every ALLOW — is written to a hash-chained, Ed25519-signed record replicated four times. Verification grants authority to a valid signature rather than to a content

majority, so an insider who rewrites three of four copies still loses to the one they missed. Detection and repair are themselves recorded as audit events, so an incident survives its own fix. A background sweep re-verifies the entire chain every 300 seconds.

5. Technology used

Layer	Technology	Notable decision
Mobile app	React Native 0.81, Expo SDK 54, React 19, React Navigation 7, TypeScript	Single codebase; strict typing across the API boundary, with a contract test that asserts response shapes the screens depend on.
Admin dashboard	Browser-based console	Runs the red-team scenarios against the live system rather than replaying recorded results.
API	FastAPI 0.138, Pydantic v2, SQLAlchemy 2.0, Alembic	Stateless, so it scales horizontally behind a standard load balancer.
Database	PostgreSQL (managed)	Audit master and three replica tables, verification logic replica-agnostic so physical separation is a deployment change, not a redesign.
Fraud model	XGBoost + scikit-learn	Feature contract checked against the saved column order at load; on mismatch the model output is down-weighted rather than trusted blindly.
Novelty model	PyTorch autoencoder (8 KB)	One-class learning on legitimate data only. Small enough to run in-process, so no separate inference tier is required.
Explanations	Local LLM via Ollama (llama3)	Chosen over a hosted API specifically so customer data stays on bank infrastructure. Deterministic templates as fallback if unavailable.
Cryptography	Ed25519 (`cryptography`), SHA-256, bcrypt	Ed25519 for 32-byte keys, fixed 64-byte signatures and deterministic signing — no per-signature nonce to leak.

Engineering practice

The system is covered by four automated suites run against a live backend: a backend journey test (60 checks), a mobile contract test asserting the exact response shapes each screen reads (37), an admin and red-team suite (35, including all ten attack scenarios), and an audit-layer suite (36). A separate check proves the novelty detector is *quiet on normal activity* as well as loud on anomalies — an earlier version only asserted the second and passed while the model was flagging every transaction.

6. Known limitations

These are stated deliberately. An assurance document that lists only strengths is marketing.

Limitation	Assessment
Key custody	Signature authority reduces the audit guarantee to ‘the private key is safe’. Production requires an HSM or KMS with its own access trail; today the key is loaded by the service.
Replica co-location	The four copies are separate tables in one database. This defends against targeted row edits — the modelled threat — but not against loss of the whole instance.
No external anchoring	Chain heads are not published outside the system, so an attacker holding the key could in theory rebuild history wholesale.
No conversational assistant	Not built. The explainability engines already answer the questions a chatbot would field; the conversational and voice front end is not implemented.

Limitation	Assessment
FRI / MNRL not integrated	Every BLOCK emits a signed structured record containing the payload such a report needs, but the feed to the Financial Fraud Risk Indicator and the 1930 cybercrime channel is not connected.
Goal-based advice dormant	The wealth engine supports goals such as home purchase and retirement; the mobile app does not yet send them, so those branches cannot fire.
Model training data	Models are trained on synthetic behavioural data. Production accuracy would require retraining on real, labelled bank data.

7. Future enhancements — what we would build next

Priority	Enhancement	Why this order
1	**Conversational and voice assistant**	The hard part is done: seven engines already generate grounded, customer-safe explanations in three languages. Adding a conversational and voice front end is an interface layer, not new intelligence — and voice matters most for the customers least served by dense financial screens.
2	**FRI / MNRL and cybercrime-cell integration**	The trigger point and the payload already exist on every BLOCK. Connecting the reporting feed and a call-centre handoff turns customer-side detection into industry-wide signal.
3	**Key custody in an HSM**	This is the single change that would move the audit guarantee from strong to bank-grade, because it closes the one boundary the current design depends on.
4	**Physically separated replicas and external anchoring**	Distribute the four copies across hosts and publish periodic chain checkpoints externally, closing the whole-instance and rebuilt-history cases.
5	**Goal-based financial planning**	Engine support exists; wiring goals through the app unlocks home-purchase, education and retirement advice with no new modelling.
6	**SIM-swap and telecom signals**	Already registered in the risk weights at zero weight. SIM-swap is a dominant real-world takeover vector and the slot is waiting for the feed.
7	**Retraining on real labelled data**	Replaces synthetic training data and would let us publish honest precision and recall rather than behavioural demonstrations.

8. Benefits

Existing customers	Fewer unnecessary interruptions, because thresholds are personal rather than fixed. When they *are* stopped, they are told why, in their own language, and can verify a different way or reject the transaction outright.
New customers	Onboarding that issues an identifier rather than demanding documents, a consent gate that makes data use explicit before anything is aggregated, and first advice that is honest about whether they should be investing at all.
The bank	Fraud stopped before funds move rather than reconciled afterwards; an audit trail defensible against a privileged insider; decision logic that can be explained to a regulator field by field; and novelty detection covering attacks nobody has written a rule for yet.

Every figure, threshold and test result in this document was read from the implementation or from live test output. Replace **[TEAM NAME]** before submission and confirm the spelling of each team member's name.